



Contoso Engineering (illustrative mock)

# Roadmap AI-SDLC G3

Proteger, entregar y fundamentos

|                           |            |
|---------------------------|------------|
| FECHA DEL ASSESSMENT      | 2026-09-27 |
| VERSIÓN DEL FRAMEWORK     | 2.0.1      |
| PERSONAS QUE RESPONDIERON | 14         |
| GENERADO EL               | 2026-09-29 |

## G3: Proteger, entregar y fundamentos

| ID | DIMENSIÓN                                        | PUNTAJE | NIVEL         | OBJETIVO | BRECHA | PRIORIDAD | HORIZONTE         |
|----|--------------------------------------------------|---------|---------------|----------|--------|-----------|-------------------|
| D6 | Seguridad y cadena de suministro de IA           | 1,90    | L2 Adoptando  | 3,00     | 1,10   | P2 Medio  | Semestre          |
| D7 | Entregar y operar                                | 1,75    | L2 Adoptando  | 3,00     | 1,25   | P2 Medio  | Semestre          |
| D8 | Fundamentos de ingeniería (amplificadores de IA) | 1,09    | L1 Explorando | 3,00     | 1,91   | P1 Alto   | Próximo trimestre |

## D6: Seguridad y cadena de suministro de IA

OWASP enumera prompt injection (LLM01:2025), supply chain (LLM03:2025) y agencia excesiva (LLM06:2025) entre los principales riesgos [38], y agent goal hijack (ASI01) en primer lugar para aplicaciones agentic [39]; NIST SP 800-218A agrega al SSDF prácticas para el desarrollo de modelos de IA [40].

**Baja confianza: Más del 30% de las respuestas son NA.**

### Empiece aquí

#### D6-Q5 AI supply chain (1,50, L1)

**Meta L3:** Un proceso de review cubre componentes de IA; SBOMs y procedencia de build se producen para la mayoría de los builds.

**Luego L4:** La procedencia se verifica en el deploy (por ejemplo metas de nivel SLSA); los componentes no evaluados se bloquean automáticamente. [38][40][43][52]

#### D6-Q6 Threat modeling para features y agentes de IA (1,62, L2)

**Meta L3:** Se requieren threat models para nuevas features de IA y workflows de agentes, y seguridad los revisa.

**Luego L4:** Los threat models se actualizan después de incidentes y ejercicios de red team; los controles se verifican mediante pruebas automatizadas. [38][39][40]

#### D6-Q4 Least privilege para agentes (1,71, L2)

**Meta L3:** Los permisos de agentes se documentan y revisan; los agentes no pueden acceder a credenciales de producción ni hacer push a protected branches.

**Luego L4:** Los permisos son just-in-time y limitados en el tiempo; el acceso se revisa automáticamente. [7][19][38][39]

### Estrategias recomendadas

- S6 Agentic Activation (P2 Medio, Semestre)
- S7 Security & Governance (P2 Medio, Semestre)

### Todas las preguntas de esta dimensión

| ID    | PREGUNTA                                      | PUNTAJE | N  | NA | EVIDENCIAS |
|-------|-----------------------------------------------|---------|----|----|------------|
| D6-Q1 | Scanning de base en todo repositorio          | 2,00    | 7  | 7  | 4          |
| D6-Q2 | Remediación asistida por IA                   | 2,09    | 11 | 3  | 5          |
| D6-Q3 | Defensas contra prompt injection para agentes | 2,25    | 8  | 6  | 6          |
| D6-Q4 | Least privilege para agentes                  | 1,71    | 7  | 7  | 3          |
| D6-Q5 | AI supply chain                               | 1,50    | 4  | 10 | 1          |
| D6-Q6 | Threat modeling para features y agentes de IA | 1,62    | 8  | 6  | 1          |
| D6-Q7 | Rastro de auditoría para acciones de agentes  | 2,08    | 12 | 2  | 4          |

## D7: Entregar y operar

más cambios generados por IA necesitan redes de seguridad sólidas en la entrega [3], [5]; Microsoft recomienda observación continua de la actividad de agentes [19] y está extendiendo agentes a operaciones de cloud [22].

### Empiece aquí

#### D7-Q4 Observabilidad de agentes (1,57, L1)

**Meta L3:** Los runs de agentes emiten telemetría al stack central de observabilidad; los dashboards muestran fallas y costo por agente.

**Luego L4:** Las alertas se disparan por drift de agentes, picos de error o anomalías de costo; los hallazgos alimentan gobernanza (D1). [19][32][45]

#### D7-Q1 IA en pipelines CI/CD (1,69, L2)

**Meta L3:** Los pipelines son code en la mayoría de los repositorios; el análisis de fallas asistido por IA está disponible para todos los equipos.

**Luego L4:** Los agentes proponen correcciones y optimizaciones de pipeline automáticamente, bajo review, con tiempo de build y tasa de fallas rastreados. [16][17]

#### D7-Q3 Respuesta a incidentes asistida por IA (1,71, L2)

**Meta L3:** Los ingenieros de on-call en la mayoría de los equipos usan IA para triage y resúmenes; las revisiones post-incidente registran si la IA ayudó.

**Luego L4:** Los agentes de operaciones ejecutan diagnósticos aprobados automáticamente; el tiempo de restauración se compara antes y después de la adopción. [16][17][22]

### Estrategias recomendadas

- S2 Foundry + SRE (P1 Alto, Próximo trimestre)
- S6 Agentic Activation (P2 Medio, Semestre)

### Todas las preguntas de esta dimensión

| ID    | PREGUNTA                                         | PUNTAJE | N  | NA | EVIDENCIAS |
|-------|--------------------------------------------------|---------|----|----|------------|
| D7-Q1 | IA en pipelines CI/CD                            | 1,69    | 13 | 1  | 4          |
| D7-Q2 | Entrega progresiva y rollback                    | 1,83    | 12 | 2  | 8          |
| D7-Q3 | Respuesta a incidentes asistida por IA           | 1,71    | 14 | 0  | 6          |
| D7-Q4 | Observabilidad de agentes                        | 1,57    | 14 | 0  | 5          |
| D7-Q5 | Infraestructure as code con guardrails           | 1,85    | 13 | 1  | 7          |
| D7-Q6 | Automatización operacional impulsada por agentes | 1,86    | 14 | 0  | 6          |

## D8: Fundamentos de ingeniería (amplificadores de IA)

DORA encuentra que estas capacidades amplifican los beneficios de la adopción de IA, y que una plataforma interna de alta calidad se correlaciona con la capacidad de desbloquear valor de IA [1], [3].

### Empiece aquí

#### D8-Q7 Pruebas automatizadas como sistema de control (0,75, L0)

**Meta L3:** La mayoría de los servicios tiene pruebas automatizadas por capas que se ejecutan en cada PR dentro de time budgets acordados.

**Luego L4:** Las suites de prueba se ajustan a partir de datos de defectos escapados; el tiempo de feedback se rastrea y mejora. [3]

#### D8-Q4 Ecosistema de datos saludable (0,92, L1)

**Meta L3:** Los datos clave están catalogados con responsables e indicadores de calidad; la mayoría de las preguntas puede responderse en una hora.

**Luego L4:** La calidad de datos se monitorea automáticamente; existen linaje y contratos para datos críticos. [1][2]

#### D8-Q5 Entornos reproducibles para humanos y agentes (1,00, L1)

**Meta L3:** La mayoría de los repositorios define un entorno reproducible; los agentes usan la misma definición.

**Luego L4:** Los entornos inician en minutos para cualquier repositorio; se detecta drift respecto de la definición. [8]

### Estrategias recomendadas

- S2 Foundry + SRE (P1 Alto, Próximo trimestre)
- S3 App Modernization (P1 Alto, Próximo trimestre)
- S1 GitHub Migration (P1 Alto, Próximo trimestre)

### Todas las preguntas de esta dimensión

| ID    | PREGUNTA                                      | PUNTAJE | N  | NA | EVIDENCIAS |
|-------|-----------------------------------------------|---------|----|----|------------|
| D8-Q1 | Control de versiones para todo                | 1,07    | 14 | 0  | 8          |
| D8-Q2 | Frecuencia de commit y rollback rápido        | 1,23    | 13 | 1  | 3          |
| D8-Q3 | Plataforma interna de calidad                 | 1,29    | 14 | 0  | 5          |
| D8-Q4 | Ecosistema de datos saludable                 | 0,92    | 13 | 1  | 6          |
| D8-Q5 | Entornos reproducibles para humanos y agentes | 1,00    | 14 | 0  | 2          |
| D8-Q6 | Documentación como contexto listo para IA     | 1,36    | 14 | 0  | 8          |
| D8-Q7 | Pruebas automatizadas como sistema de control | 0,75    | 12 | 2  | 9          |

## Referencias

---

- [1] DORA. DORA AI Capabilities Model. Google Cloud, 2025. <https://dora.dev/ai/capabilities-model/report/>
- [2] DORA. DORA AI Capabilities Model: Survey Questions. Google Cloud, 2025. <https://dora.dev/ai/capabilities-model/questions/>
- [3] Google Cloud. Announcing the 2025 DORA Report: State of AI-Assisted Software Development. 2025. <https://cloud.google.com/blog/products/ai-machine-learning/announcing-the-2025-dora-report>
- [7] GitHub Docs. Risks and mitigations for GitHub Copilot cloud agent. <https://docs.github.com/en/enterprise-cloud@latest/copilot/concepts/security-governance-and-network-settings/risks-and-mitigations>
- [8] GitHub Docs. Best practices for using GitHub Copilot to work on tasks. <https://docs.github.com/en/enterprise-cloud@latest/copilot/tutorials/cloud-agent/get-the-best-results>
- [16] Microsoft Azure Blog. Agentic DevOps: Evolving software development with GitHub Copilot and Microsoft Azure. 2025. <https://azure.microsoft.com/en-us/blog/agentic-devops-evolving-software-development-with-github-copilot-and-microsoft-azure/>
- [17] Microsoft for Developers. Agentic DevOps in action: Reimagining every phase of the developer lifecycle. 2025. <https://developer.microsoft.com/blog/reimagining-every-phase-of-the-developer-lifecycle/>
- [19] Microsoft Learn. Govern and secure AI agents: Cloud Adoption Framework. <https://learn.microsoft.com/en-us/azure/cloud-adoption-framework/ai-agents/governance-security-across-organization>
- [22] Microsoft Azure Blog. Announcing Azure Copilot agents and AI infrastructure innovations. 2025. <https://azure.microsoft.com/en-us/blog/announcing-azure-copilot-agents-and-ai-infrastructure-innovations/>
- [32] Gartner. Gartner Predicts AI Coding Costs Will Surpass Average Developer's Salary by 2028 as Token Consumption Surges. 2026-06-24. <https://www.gartner.com/en/newsroom/press-releases/2026-06-24-gartner-predicts-ai-coding-costs-will-surpass-average-developer-salary-by-2028-as-token-consumption-surges>
- [38] OWASP GenAI Security Project. OWASP Top 10 for LLM Applications 2025. <https://genai.owasp.org/resource/owasp-top-10-for-llm-applications-2025/>
- [39] OWASP GenAI Security Project. OWASP Top 10 for Agentic Applications for 2026. 2025-12-09. <https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/>
- [40] NIST. SP 800-218A: Secure Software Development Practices for Generative AI and Dual-Use Foundation Models: An SSDF Community Profile. 2024-07. <https://csrc.nist.gov/pubs/sp/800/218/a/final>
- [43] OpenSSF. SLSA: Supply-chain Levels for Software Artifacts. <https://slsa.dev/>
- [45] Liu, B., Qiu, H., Goiri, Í., Fonseca, R., Bianchini, R., Choukse, E. Agentic Coding in the Wild: Characterizing GitHub Copilot Traces at Production Scale. arXiv:2608.00101, 2026-07-30. <https://arxiv.org/abs/2608.00101>
- [52] Sakib, A. H. M. N., Banik, D., Jadhwal, M. Trust but Verify? Uncovering the Security Debt of Autonomous Coding Agents. arXiv:2607.12428, 2026-07-14. <https://arxiv.org/abs/2607.12428>